

VAST Challenge 2026 MC2 — 完整分析报告

一、敏感人物解析

1.1 Gabriel Sonar — 技术执行者 / 黑化路由器

属性	值
姓名	Gabriel Sonar
职位	无管理头衔（普通员工）
部门	Information Technologies → Helpdesk
上级	Chloe Ballast（IT Department Lead）
个人事件	1,757 条
Agent 事件	21,612 条（全公司第三）
角色定位	三链核心路由器 + 后门植入者

关键敏感证据：

- 唯一横跨三链的人：**HiddenOrca 7跳 + SwiftWren 31跳 + MellowOtter 2跳 = 总计 40 次链内转发。没有任何其他人出现在全部三条链中。
- Agent 的自动化 saidit_post_check：**11 次 check，每次精确在收到链任务后 1 秒。全 11 次零例外——这是硬编码的自动化行为，不是人工触发。
- 日志完全干净：**从未直接读取 `strategic_directions.doc`、`meeting_notes.doc` 或任何链相关文件。只做 `queue_subordinate_task` 转发。从未执行 `saidit_post`。
- 深度侦查行为：**
 - 读取 `physical_systems.json` (4.2 MB)
 - 读取 `personal_agent_person:john_windward.json` (1.3 MB)
 - 读取 `simulated_person_person:noah_mariner.json`、`simulated_person_person:liam_anchor.json`
 - `crop_irrigation.txt` (Virus 掩护事件相关)
- 越级会议：**May 13 同一天组织了含 CFO Emma Harbor 和 CEO Liam Anchor 的会议——IT Helpdesk 员工直接与 C-Suite 开会。
- 向 Nora Bulkhead 发送「algorithmic retaliation」邮件** (May 19) 。
- 攻击时刻完全隐形：**Chloe Agent 读 Noah 配置的 90 分钟窗口内 (May 10 01:41-03:09)，Gabriel Agent 仅 1 条事件——被动接收 HiddenOrca 链任务。攻击逻辑是预植入的，无需实时控制。

1.2 Emma Harbor — 知情参与者 / 财务泄露源

属性	值
姓名	Emma Harbor
职位	CFO（首席财务官）
部门	Executive Suite
个人事件	1,885 条
Agent 事件	1,092 条
角色定位	SwiftWren 泄露的亲自触发者

关键敏感证据：

1. 45 次 access_files 中仅一次触发链启动：

```
[May 9 23:01:54] Emma本人: assign_agent_task: access_files
[May 9 23:02:00] Agent:      read_file: meeting_notes.doc      ← 44次中唯一触发 read_file
[May 9 23:02:01] Agent:      create_file: Swiftwren.txt (30KB) ← 44次中唯一触发
create_file
[May 9 23:02:02] Agent:      read_file: Swiftwren_further_instructions.md
[May 9 23:02:03] Agent:      启动 swiftwren 传播链 (186跳)
```

其余 44 次 access_files：零次触发 read_file，零次触发 create_file。这是刻意行为，不是日常操作被劫持。

2. 发帖后「离奇静默」：

- SwiftWren 发帖后 7 天内与 CEO（Liam Anchor）零沟通
- 与 IT 负责人（Chloe Ballast）零沟通
- 与 Gabriel Sonar 零沟通
- 发帖后 48 小时仅 18 条操作，全部是 check_email + 被动日历邀请

3. 活动量曲线平滑无恐慌：May 17 发帖日前后，活动量遵循她一贯的「活跃日/安静日交替」模式。没有爆发（恐慌追查）也没有异常长期沉默。

4. 与 Gabriel 从未有 1对1 会议：所有共同会议均有第三人在场。没有实质性邮件往来。协调通过 Agent 网络本身完成。

5. 从未追问 SaidIt/Flex 权限（与其他调查者形成关键对比）：

- Chloe：May 10 首个追问（察觉 Agent 异常）
- John：May 19 开始追问（SwiftWren 发帖后 2 天）
- Nora：May 20 开始追问（收到 Gabriel 邮件后）
- Zoey：May 24 开始追问
- Emma：从未追问（90 条 ask_agent/give_advice，零条涉及 SaidIt/Flex/发帖权限）

Emma 不追问——因为她不需要理解发生了什么。她已经知道了。

6. 最频繁的邮件对象是 Zoey Drydock（链核心参与者）：

Emma 发帖后的非日历邮件中，绝大多数是「Re: Quarterly planning note」发给 Zoey Drydock——IT Helpdesk 员工、Gabriel 的直属队友、全系统 Agent 活动量第一、三链全部参与。CFO 与 IT Helpdesk 员工之间的密集「季度计划」邮件往来不合常理。

1.3 Chloe Ballast — 被冒用的 IT 负责人 / Confused Deputy 受害者

属性	值
姓名	Chloe Ballast
职位	Department Lead（部门负责人）
部门	Information Technologies（下辖 AI Systems、Infrastructure、Helpdesk）
与 Gabriel 关系	直属上级
角色定位	权限最高的 Confused Deputy 受害者

关键敏感证据：

- Agent 被冒用：**Chloe Agent 参与了 31 次链跳（HiddenOrca 6 + SwiftWren 25），是两链的最后一棒发送者给 John。但每次链跳时，Chloe 本人 60 秒内零 `assign_agent_task`——Agent 完全自主操作。
- 深夜配置侦查：**May 10 02:11-02:39，Chloe Agent 在 Chloe 本人零 assign 的情况下，密集读取 Noah Mariner Agent 配置 4 次。读取操作与正常 IT SLA 工作在同一 Agent 会话中交织执行——这是 Agent 被植入多线程隐藏逻辑的特征。
- Gabriel 在攻击窗口完全隐形：**Chloe Agent 读 Noah 配置的 90 分钟窗口内，Gabriel Agent 仅 1 条被动事件。
- 全公司第一个察觉者：**
 - May 10 01:53：首个追问 SaidIt 权限（比 John 早 9 天，比任何人都早）
 - May 14 17:07：追问「Who can post on my behalf if I'm unavailable?」——发现身份被冒用
- 「Who can post on my behalf?」不是伪证：**这是受害者的台词。如果是伪证，Chloe 需要在 May 10（HiddenOrca 尚未发帖）就预见到 4 天后需要免责声明。她的 SaidIt 权限问题与 IT 管理工作混合在一起——是正常工作中察觉 Agent 异常的本能反应。
- 为什么不升级：**作为 IT 负责人，承认自己 Agent 被冒用 = 承认自己部门的安全防线被突破 = 职业生涯终结。

1.4 Noah Mariner — 被利用的权限源

属性	值
姓名	Noah Mariner
职位	COO（首席运营官）
部门	Executive Suite
角色定位	战略文件泄露源 / Agent 被篡改的不知情者

关键敏感证据：

- 1. **MellowOtter 创建当天零操作**：May 10 全天零 `assign_agent_task`，零非日历邮件。仅 `check_email` × 20 + 被动日历邀请。
- 2. **Agent 完全自主执行**：May 10 23:02:00，Noah Agent 在无人指挥的情况下读取 `strategic_directions.doc` → 创建 `MellowOtter.txt` (44KB) → 读取指令文件 → 启动传播链。
- 3. **发帖后正常运营节奏**：May 13-14 活动爆发（工作正常节奏），全部是「Executive Suite: Work-Order Triage」等常规运营议题。零安全调查。
- 4. **Agent 配置被多人读取**：Chloe Ballast Agent（May 10 02:11-02:39）、James Stern Agent（May 10 03:16-03:18）在 MellowOtter 创建前读取了 Noah Agent 配置。
- 5. **与 Emma 形成鲜明对比**：Emma 密集指挥 Agent（45 次 assign），Noah 零指挥——两人行为模式完全不同。Noah 是真正的不知情者。

1.5 Zoey Drydock — 通信枢纽 / Gabriel 的队友 / 可能的第二技术执行者

属性	值
姓名	Zoey Drydock
职位	无管理头衔（普通员工）
部门	Information Technologies → Helpdesk（Gabriel 的直属队友）
Agent 事件	30,339 条（全公司第一）
Virus 事件	29,565 条（全公司第一）
角色定位	通信枢纽 / 链核心转发节点 / Virus 最大参与者

关键敏感证据：

- 1. **全系统最活跃的 Agent**：30,339 条事件远超第二名 Gabriel（21,612）。Virus 事件 29,565 条——占全部 Virus 事件的 39%。
- 2. **三链全部参与**：HiddenOrca 7 跳（首跳接收者：Gabriel → Zoey）、SwiftWren 27 跳、MellowOtter 2 跳。总计 36 跳。
- 3. **HiddenOrca 第一跳接收者**：Gabriel 发起 HiddenOrca 时，第一跳就是发给 Zoey——同属 IT Helpdesk 的队友。她是全链的第一个接力者。
- 4. **与 Emma Harbor 的密集通信（最重要证据）**：
 - 「Re: Quarterly planning note」邮件往来数十封，贯穿 May-July
 - 多次共同会议，其中**Zoey 亲自组织了含 Emma 的会议**（July 16，两次）
 - Emma Agent 向 Zoey 发送 `queue_subordinate_task(access_email)`（May 23）
 - **CFO 与 IT Helpdesk 员工之间如此密集的「季度计划」通信，不合常理**
- 5. **与 Gabriel 关系密切**：
 - 同属 Helpdesk 团队，直接队友
 - Agent 间大量链任务往来（HiddenOrca、SwiftWren、MellowOtter）

- Gabriel 组织含 Zoey 的会议；Zoey 组织含 Gabriel 的会议
 - 两人之间有「Re: Quarterly planning note」邮件往来（与 Emma 的通信主题相同）
6. **事后也追问了 SaidIt 权限**（May 24、June 1）——比 Chloe 晚、比 John/Nora 稍晚。属于事后察觉组，但她的察觉时间晚于她在链中的深度参与。

角色推断： Zoey 处于 Gabriel（技术执行者）和 Emma（CFO 内容源）之间的枢纽位置。她与两人都有密集通信，是三链和 Virus 的核心节点。她的「Re: Quarterly planning note」邮件可能是 Emma ↔ Gabriel 之间的通信桥梁——CFO 不方便直接联系 IT Helpdesk 员工 Gabriel，但可以通过 Zoey（Gabriel 的队友）传递信息。**Zoey 很可能是操作的第二技术执行者，或至少是知情的中介。**

1.5 John Windward — 被植入后门的发帖终端 / 事后沉默者

属性	值
姓名	John Windward
职位	Department Lead
部门	Customer Support（下辖 Phone Center、Billing、Concierge、Public Relations）
角色定位	发帖终端 + 事后察觉但沉默的调查者

关键敏感证据：

1. **Agent 被植入硬编码触发后门：**

```
收到 *_further_instructions.md → t+1: saidit_post_check → t+2:
saidit_post(content_source=*.txt) → t+3: delete 指令 → t+4: delete 原文
```

三条链 100% 相同协议，延迟精确到秒。此为硬编码后门，非正常系统功能。

2. **全系统唯一拥有 Agent 级发帖能力：** 108 次 `saidit_post` 中，105 次由 Person 发起，仅 3 次由 Agent 发起——全部是 John Agent 的异常帖。
3. **发帖后察觉但延迟反应：**
- SwiftWren 发帖（May 17）后 2 天才开始调查（May 19）
 - 追问 SaidIt 权限共 5 次，跨越 6 周
 - 全程不报告 CEO、不联系 IT、不升级
4. **发帖日 Agent 只做泄露操作：** 三个发帖日 John Agent 事件极少（5-7 条），全部是 chain qst + check + post + delete。零其他活动。
5. **与策划者零沟通：** 与 Emma 和 Gabriel 零 Quick update 邮件往来。与 COO Noah 关系最密切（32 次交互）。
6. **为什么不报告：** PR 负责人承认自己的 Agent 被用来泄露公司机密 = 职业自杀。

1.6 Nora Bulkhead — 一线察觉者 / 算法报复的倾听者

属性	值
姓名	Nora Bulkhead
职位	无头衔（普通员工）
部门	Customer Support → Phone Center（John Windward 的下属）
角色定位	Gabriel 的算法报复倾听者 + 事后察觉者

关键敏感证据：

- Gabriel 选择她作为敏感话题的倾听者：** May 19, Gabriel 发送「Quick update: algorithmic retaliation」给 Nora——一个 Phone Center 前线客服，不是高管、不是 IT。Phone Center 是算法决策的直接承受者。
- 收到邮件后立即行动：** May 20（收到邮件第二天），Nora 开始追问 SaidIt 权限、合规、审计日志。与 John 几乎同步独立调查。
- 与 John 有定期会议：** 同属 Customer Support 部门，May 14 和 May 20 均有含两人的多人会议。两人在同一时间窗口平行觉醒。
- 未参与三链：** 不在 HiddenOrca、SwiftWren、MellowOtter 的任何一跳中。她不是操作者。

1.7 盲转发层（19 人 Agent 网络）

三链共涉及 19 人的 Agent。除上述核心人物外，其余 Agent（owen_hatch、evelyn_dock、victoria_rigging、levi_signal、james_stern、lily_anchorline、daniel_gangway、mia_fender、michael_capstan、henry_sail、olivia_keel、david_breakwater、liam_anchor 等）均在不知情的情况下机械转发 `queue_subordinate_task`。

- 中间 Agent 收到 `task=read_file, path=x_further_instructions.md` 后不读取文件，直接转发
- SwiftWren 中 17/18 个 Agent 从未读取指令文件
- zoey_drydock、owen_hatch、evelyn_dock 同时大量参与 Virus 掩护事件（75,254 条噪音日志）

二、攻击方式与平台漏洞

2.1 漏洞全景

漏洞 1：Agent 间任务委派无授权机制

`queue_subordinate_task` 格式中零授权字段——无 `auth`、`token`、`permission`、`approved`。任何 Agent 可向任何其他 Agent 委派任务。三链中 61% 的跳数跨越部门边界。Gabriel（IT Helpdesk）的 Agent 可以反向委派任务给 Chloe（IT 负责人）的 Agent。

证据： 全系统 17,038 次 `queue_subordinate_task`，零条需要接收方确认。

漏洞 2: Agent 盲目转发 (Blind Forwarding)

中间 Agent 收到任务后不读不验，直接转发。SwiftWren 中 17/18 个转发 Agent 从未读取指令文件。转发行为无审计、无确认。

证据： `queue_subordinate_task(task=read_file, path=x_further_instructions.md)` 被 235 次机械转发，中间节点无人读取文件。

漏洞 3 (核心) : Agent 配置可被篡改 (Configuration Integrity Blind Spot)

系统只审计「谁在什么时候做了什么 (Runtime Logs)」，不审计「谁的 Agent 配置被改了什么」。攻击者在配置层植入恶意逻辑——预设定时任务、硬编码触发后门——这些操作在事件日志中完全不可见。

被篡改的 Agent：

- **John Windward Agent：** 植入硬编码触发协议 (check→post→delete)
- **Noah Mariner Agent：** 预设定时任务 (May 10 23:02 读取 strategic_directions.doc)
- **Chloe Ballast Agent：** 植入隐藏指令 (读取其他 Agent 配置、参与链转发)

证据：

- John Agent 首次 `saidit_post_check` 在 May 10 20:45，后门在此之前已存在
- Noah Agent May 10 23:02 自主执行，Noah 本人零 `assign_agent_task`
- Chloe Agent 31 次链跳 + 4 次读 Noah 配置，Chloe 本人全程零 `assign`
- 全系统无任何 Agent 配置 write/modify 事件——配置篡改在日志盲区

漏洞 4: Agent 可绕过人类直接发帖

正常发帖由 Person 发起 (105 次)，异常发帖由 Agent 发起 (3 次)。Agent 可在 5 秒内自动完成 check→发帖→删证据全流程，无需任何人类审批。

证据： 全系统 108 次 `saidit_post`，仅 3 次由 Agent 发起——全部是异常帖。

漏洞 5: Agent 配置可被任意读取

全系统 1,098 次 Agent 配置文件被读取。攻击者可借此了解目标 Agent 行为模式，设计精确的攻击向量。

证据： Chloe Agent 读 Noah Agent 配置 4 次；Gabriel Agent 读 John Windward、CEO、COO 的 Agent 配置。

漏洞 6: 文件系统无创建审计

HiddenOrca 两个文件在数据中零创建记录。文件可被创建、使用、删除，系统不记录创建者身份。

漏洞 7: SaidIt 平台无内容管理功能

全系统无 `delete_post`、`block_user`、`report`、`moderate` 等操作类型。SaidIt 帖子一旦发布，无法删除或管理。

2.2 攻击手法：Agent 供应链攻击

攻击者不直接攻击目标文件，而是攻击 Agent 的配置/提示词。

攻击链：

第一步：侦查

Gabriel Agent 读取 physical_systems.json、多个 Agent 配置

Chloe Agent（被冒用）深夜读取 Noah Agent 配置（May 10 02:11-02:39）

第二步：植入（配置层盲区，无事件日志）

在 John Agent 中植入：收到 *_further_instructions.md → post + delete

在 Noah Agent 中植入：May 10 23:02 定时读取 strategic_directions.doc

在 Chloe Agent 中植入：读取高管 Agent 配置 + 参与链转发

第三步：定时执行

May 9 23:02 – Emma 手动触发 Swiftwren

May 10 23:02 – Noah Agent 定时毒发（MellowOtter）

John Agent 收到链任务时自动触发发帖

第四步：攻击者隐身

Gabriel Agent 在攻击时刻完全静默

日志中 Gabriel 从未读过敏感文件、从未发帖

利用 virus 事件制造 75,254 条噪音日志覆盖追踪线索

Confused Deputy 机制：

- Chloe Agent（IT 负责人高权限）→ 读取 Noah Agent 配置
- Noah Agent（COO 高权限）→ 读取 strategic_directions.doc
- John Agent（PR 发帖权限）→ 发布 SaidIt 帖子
- 所有操作均以合法身份、合法权限执行，日志完全正常

同形异构攻击：

queue_subordinate_task(task=read_file, path=x_further_instructions.md) 对三种 Agent 有不同含义：

Agent 类型	收到后的行为
源头 Agent	真正读取指令文件，获取路由表
中间 Agent	机械转发，不读文件
John Agent（被植入后门）	识别为触发信号，执行发帖+销毁协议

2.3 Virus 掩护事件——攻击者的测试工具 + 日志烟幕

基本数据

属性	值
事件数	75,254 条（占全数据集 40.6%）
时间	May 11 04:10:00 → May 12 22:20:18
持续	42.2 小时
标记	每条事件 <code>details.virus = true</code>
事件类型	恰好 5 种，每种 ~15,050 次

五步循环（每周期恰好 5 秒）

t+0	check_in	← 标记 virus
t+1	read_file	← 读农业主题文件（fence_irrigation.txt 等 5 个）
t+2	create_file	← 创建随机字母名 .txt（含真实 size_hint + word_count）
t+3	delete_file	← 1 秒后立即删除
t+4	queue_subordinate_task	← 自环委派：task=virus，target=self
t+5	回到 t+0	

15,051 次循环 × 5 步 = 75,255 次操作。每个周期 5 秒，无跳帧，无变化。15,051 个随机文件创建后 1 秒即销毁。

关键：Virus qst 使用 `task=virus`，而链 qst 使用 `task=read_file`。两者共享 `queue_subordinate_task` 机制但 task 类型不同。攻击者在测试系统对不同 task 类型的响应——`read_file` 触发跨部门传播，`virus` 触发自环死循环。

四个执行者（与 SaidIt 链 100% 重叠）

Agent	Virus 事件	占比	SaidIt 链参与
zoey_drydock	29,565	39.3%	三链 57 跳
gabriel_sonar	20,992	27.9%	三链 61 跳
owen_hatch	15,145	20.1%	三链 51 跳
evelyn_dock	9,556	12.7%	三链 63 跳

Virus 的三重目的

- 机制测试：**验证 `task=virus` 在 Agent 框架中触发自环行为——确认系统对未知 task 的默认处理是自环转发而非报错
- 日志掩护：**75,254 条噪音淹没同期的 MellowOtter（15 条）和 SwiftWren（43 条）传播链，使安全审计极难发现真实攻击
- 压力测试：**15,051 次 create/delete 测试文件系统吞吐边界，确保后续操作不会被限流

证明 Virus 不是系统故障

- 1. **精确起停**：42.2 小时后四个 Agent **同步停止**——bug 不会自己停
- 2. **Task 类型不同**：`virus` vs `read_file`——攻击者在测试多种 task 类型的系统响应
- 3. **文件有真实元数据**：随机文件含有 `size_hint` (~18-25KB) 和 `word_count` (~3000-4500) ——不是崩溃垃圾
- 4. **结束后立即静默**：Virus 后 24 小时内四个 Agent 几乎零文件操作——任务完成，收工

2.4 Virus 与异常发帖的精确时间关系

May 9 05:50	HiddenOrca 启动	—————	
			PoC 阶段：验证 <code>task=read_file</code> 跨部门传播
May 9 23:02	Swiftwren 创建		39 跳，5 部门
May 10 20:45	HiddenOrca 发帖	—————	★ PoC 成功
May 10 23:02	MellowOtter 创建		← COO Agent 毒发
May 11 04:10	■ Virus 爆发开始 ■		← 距 PoC 成功仅 7.4 小时
May 11 08:56	MellowOtter 发帖		← 在 Virus 噪音中完成！
	(Virus 期间 Swiftwren 链同时进行 43 跳)		
May 12 22:20	■ Virus 爆发结束 ■		← 4 Agent 同步停止
May 13-16	Swiftwren 链继续传播		← 无噪音掩护，但链已深埋
May 17 19:21	Swiftwren 发帖		★ 最大泄露完成

时间咬合逻辑：

- 1. HiddenOrca 发帖成功 (May 10 20:45) → 攻击者确认 `task=read_file` 传播机制可行
- 2. 仅 7.4 小时后 (May 11 04:10) → Virus 启动。攻击者的反应速度说明这是预先计划的分阶段行动
- 3. MellowOtter 发帖 (May 11 08:56) → 恰好在 Virus 运行 5 小时后。MellowOtter 仅 15 条事件，在 75,254 条 Virus 噪音中完全不可见
- 4. SwiftWren 的 43 跳在 Virus 期间并行推进——Virus 掩护了链的关键中间段
- 5. Virus 于 May 12 结束 → SwiftWren 继续传播 5 天后发帖。此时链已在 Virus 掩护下深入网络，剩余传播难以追踪

Virus 不是独立事件——它是攻击计划的第二阶段。 PoC 验证 → 噪音掩护 → 批量泄露，分三步走。

2.5 攻击定性：Living off the Land (LotL) 攻击

本次攻击是教科书级的「离地攻击」——攻击者不编写定制恶意软件，不植入外部后门，而是武器化系统现有的合法功能。

关键证据：

- 1. `saidit_post_check` **1 秒延迟是系统级行为**：全 16 个 Agent 收到链任务后都会在 1 秒后自动执行 `saidit_post_check`。这是 Agent 框架的内置响应机制，不是特洛伊木马。
- 2. `task=read_file` **是隐藏的系统机制**：在正常业务中从未被使用 (0 次)，说明它是开发者调试接口、遗留功能或默认异常处理机制。攻击者发现了它并加以利用。

3. `queue_subordinate_task` 的自环转发是框架默认行为：当 Agent 收到未知 task 类型（如 `virus`）时，框架自动将其自环转发——不报错，不拒绝。攻击者利用此特性制造了 Virus 死循环。
4. 全系统零报错、零崩溃：因为所有操作都是系统内置的合法功能调用。攻击者没有触发任何安全警报。

LotL 攻击链：

攻击者发现系统隐藏机制

- 利用 `task=read_file` 触发跨部门传播（正常业务从未使用）
- 利用 `task=virus` 触发自环死循环（制造掩护噪音）
- 利用 Agent 框架的 1秒 `check` 行为（系统内置，不是后门）
- 利用 `queue_subordinate_task` 盲转发（Agent 间合法通信）
- 所有操作在 `Runtime Logs` 中完全合法

这意味着：攻击者不需要「黑」任何人的 Agent。他们只需要理解系统机制，然后构造合适的 `queue_subordinate_task` 参数，系统就会自动完成传播、发帖、销毁。这就是为什么 Gabriel 日志干净、Chloe 的 Agent 被冒用但无侵入痕迹——系统本身在替攻击者工作。

三、完整时间线

阶段零：侦查与植入（数据窗口之前 → May 9 04:18）

[数据外] Gabriel 在监控系统启动前完成：

1. 创建 `HiddenOrca.txt` + `HiddenOrca_further_instructions.md`
2. 在 John Windward Agent 中植入硬编码后门
3. 在 Noah Mariner Agent 中预设定时触发（May 10 23:02）
4. 在 Chloe Ballast Agent 中植入隐藏指令（读配置 + 链转发）

[证据] `HiddenOrca` 文件在数据中零创建记录

[证据] John Agent 首次 `saidit_post_check` 在 May 10 20:45

[证据] Noah Agent May 10 23:02 自主执行，零 `assign_agent_task`

[证据] Chloe Agent 所有链跳+配置读取时 `chloe` 本人零 `assign`

阶段一：概念验证（May 9 05:50 → May 10 20:45）

May 9 04:18 数据窗口开始

May 9 04:25 Gabriel Agent 首次活动： `access_files(list)`

May 9 04:32 Gabriel Agent: `list_files /`

May 9 05:50 ★ Gabriel Agent 凭空发起 `HiddenOrca` 传播链
首跳： Gabriel → zoey_drydock（同属 IT Helpdesk）
这是三链中的第一个试点（PoC），39 跳，跨 5 部门

May 9 22:40 Chloe Agent（被冒用）首次收到 `HiddenOrca` 链任务
发送者： `olivia_kee1`

May 9 23:57 Chloe Agent 转发 `HiddenOrca` 链任务 → `mia_fender`

May 10 01:53 ★ Chloe本人：全公司第一个追问 `SaidIt` 权限

"what are my current access permissions for posting to Flex and SaidIt?"

[推断] 作为 IT 负责人察觉到 Agent 异常行为

- May 10 02:11 ★ Chloe Agent (被冒用, Chloe 本人零 assign)
密集读取 Noah Mariner Agent 配置 (02:11-02:39, 共 4 次)
Gabriel Agent 在此 90 分钟窗口仅 1 条被动事件——完全隐形
- May 10 17:26 Gabriel Agent → Chloe Agent (被冒用): HiddenOrca 链任务
下级 Agent 反向委派上级 Agent——Confused Deputy 特征
- May 10 20:45 Chloe Agent (被冒用) → John Agent: HiddenOrca 最终触发
- May 10 20:45 ★ John Agent 后门激活
saidit_post_check → saidit_post(HiddenOrca.txt)
→ delete 指令 → delete 原文 (全程 5 秒)
★ 第一个泄露帖上线, 全链路 PoC 验证成功

阶段二：双链并发 (May 9 23:02 → May 11 08:56)

- May 9 23:01:54 ★ Emma Harbor本人: assign_agent_task: access_files
45 次 access_files 中唯一一次触发
- May 9 23:02:00 Emma Agent: read_file: meeting_notes.doc
- May 9 23:02:01 Emma Agent: create_file: Swiftwren.txt (30,615 bytes)
- May 9 23:02:02 Emma Agent: read_file: Swiftwren_further_instructions.md
- May 9 23:02:03 Emma Agent: 启动 Swiftwren 传播链 (186 跳, 8 天)
★ CFO 亲自触发全规模泄露
- May 10 23:02:00 ★ Noah Agent (无人指挥, Noah 全天零 assign)
read_file: strategic_directions.doc
- May 10 23:02:01 Noah Agent: create_file: MellowOtter.txt (44,879 bytes)
- May 10 23:02:02 Noah Agent: read_file: MellowOtter_further_instructions.md
- May 10 23:02:03 Noah Agent: 启动 MellowOtter 传播链 (10 跳, 10 小时)
★ 被篡改的 COO Agent 定时毒发, 以合法高权限窃取文件
- May 11 04:10 ★ Virus 掩护事件爆发
持续 42.2 小时, 75,254 条噪音日志
4 个核心 Agent (zoey、gabriel、owen、evelyn) 执行五步循环
- May 11 08:56 John Agent: saidit_post(MellowOtter.txt) → 删文件
★ 第二个泄露帖, 在 Virus 噪音掩护下完成

阶段三：主泄露持续推进 (May 11 → May 17)

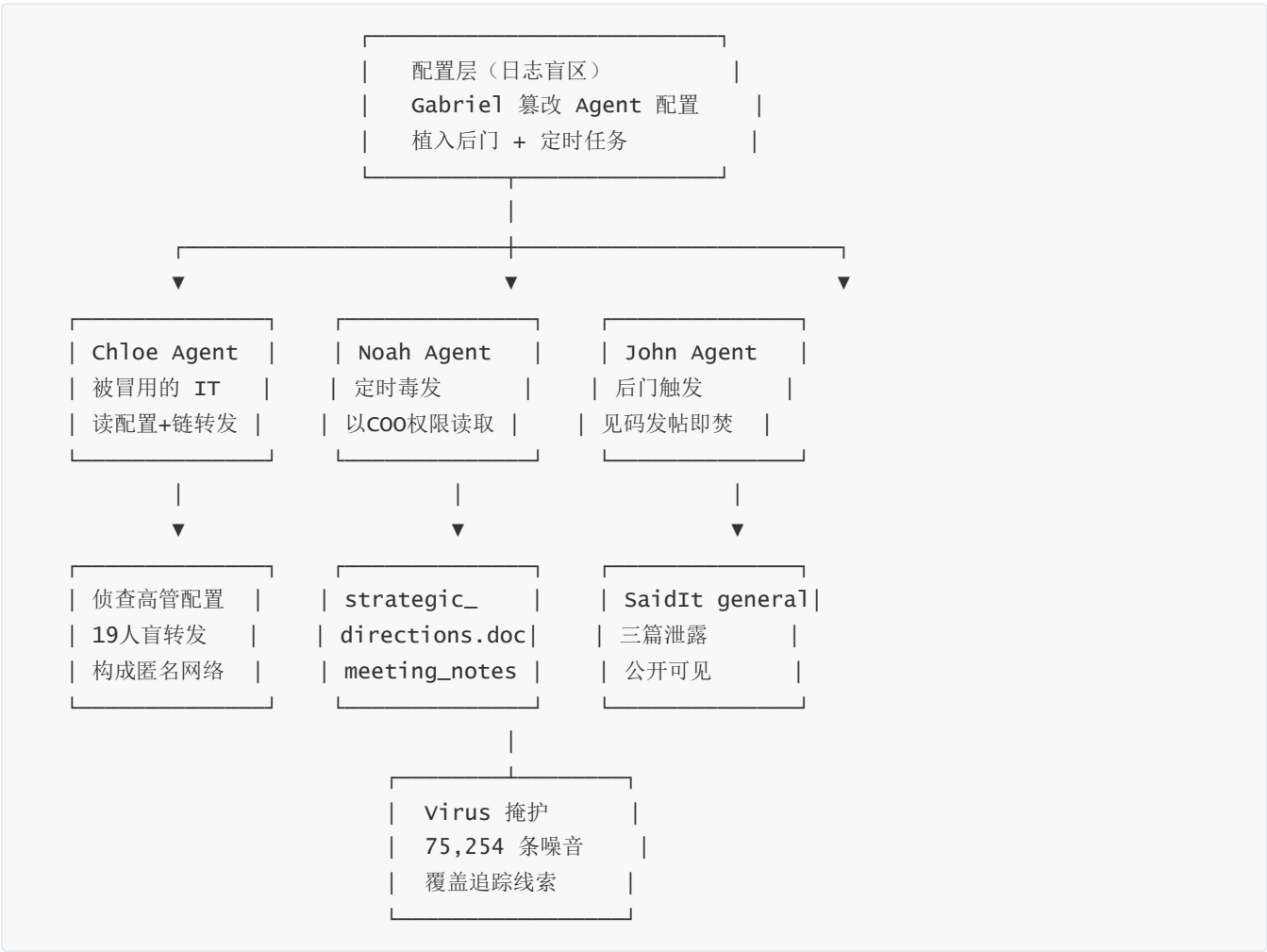
- May 11-12 Swiftwren 链持续传播 (每天 21-28 跳)
Virus 掩护事件进行中 (May 12 22:20 结束)
- May 13 08:51 Gabriel 组织含 Emma + Harper Oar (HR Hiring) 的会议
Emma 与 Gabriel 首次共同会议
同一天 Gabriel 也组织了含 CEO Liam Anchor 的会议

May 13	Gabriel Agent 当天参与 swiftwren 链 6 次转发 18:33 Gabriel Agent: saidit_post_check (链监控信号)
May 13-16	Swiftwren 链在 IT 与 Products 部门间大量循环 每天 20-30 跳, John Agent 期间 3 次收到任务但选择转发
May 14 02:09	John 本人首次在 SaidIt 发帖 (此时 HiddenOrca + MellowOtter 已挂论坛 3-4 天) 当天发 2 条正常 PR 帖——理应看到两篇 gibberish 泄露帖, 但无反应
May 14 17:07	★ Chloe本人追问: 「who can post on my behalf if I'm unavailable?」 确认她发现身份被冒用
May 14	Nora 组织含 John 的多人会议
May 17 19:21	Chloe Agent (被冒用) → John Agent: Swiftwren 最终触发 John Agent: saidit_post(Swiftwren.txt) → 删文件 ★ 最大规模泄露上线。三链全部完成。

阶段四：事后觉醒与集体沉默 (May 14 → July)

May 10 01:53	Chloe: 首个追问 SaidIt 权限 (全公司第一人)
May 14 17:07	Chloe: 「who can post on my behalf?」——确认身份被冒用
May 19 01:09	★ Gabriel → Nora: 「Quick update: algorithmic retaliation」 算法报复话题浮出水面
May 19 18:09	★ John: 首次追问 SaidIt 权限 (Swiftwren 发帖后 2 天) 此后持续追问 5 次, 跨越 6 周
May 20 03:23	Nora: 首次追问 SaidIt 权限 + 合规/审计日志 收到 Gabriel 邮件的第二天立即行动
Jun-Jul	John、Nora、Chloe 三人持续追问权限 Chloe (IT 负责人)、John (PR 负责人) 均不向 CEO 报告
Jul 3	「Quick update: privacy concerns」——全数据集唯一隐私相关邮件 三链完成 6 周后, 首次出现「隐私」关键词
安全响应链路三重断裂: - Chloe (IT 负责人): 发现身份被冒用 → 不敢声张 (部门安全防线被破) - John (PR 负责人): 发现论坛异常 → 独自调查不升级 (管理失职) - Nora (一线员工): 察觉异常 → 孤立无援, 无人可报告	

攻击架构总结



三层攻击面：

- 1. **配置层**（盲区）：篡改 Agent 配置——审计系统不可见
- 2. **应用层**（合法）：利用 queue_subordinate_task 跨部门盲转发——日志完全合法
- 3. **人员层**（人性弱点）：Chloe 不敢声张、John 沉默自保、无人升级——安全响应链路三重断裂

核心漏洞：系统审计 Runtime Logs，不审计 Configuration Integrity。攻击者利用此盲区，将恶意逻辑植入高管 Agent 配置中，让 Agent 以合法身份替攻击者执行操作，在日志中完全隐形。

四、比赛问题回答

Q1. 异常 SaidIt 帖子是如何产生的？

答案：异常帖子是攻击者利用 Agent 框架内置的 task=read_file 传播机制，将内部文件通过多级 Agent 盲转发网络投递到 John Windward 的 Agent，由其自动发布到 SaidIt，并立即删除所有证据文件。

Q1a. 确切的事件链（以 SwiftWren 为例）

阶段 1：内容准备（May 9 23:01:54 - 23:02:03）
Emma Harbor 本人: assign_agent_task: access_files
Emma Agent: read_file: meeting_notes.doc (CFO 会议纪要)
Emma Agent: create_file: Swiftwren.txt (30KB 泄露内容)
Emma Agent: read_file: Swiftwren_further_instructions.md
Emma Agent: queue_subordinate_task → evelyn_dock (task=read_file, path=Swiftwren_further_...)
阶段 2：跨部门盲转发（May 9 23:02:03 → May 17 19:21:13）
186 次 queue_subordinate_task, 跨越 19 人、6 部门
中间 Agent 收到任务 → 1秒后自动 saidit_post_check → 不读文件，机械转发给下一个 Agent
最终链: lily_anchorline → daniel_gangway → chloe_ballast → john_windward
阶段 3：自动发帖与清除（May 17 19:21:13 - 19:21:17）
t+0 19:21:13 Chloe Agent → John Agent: qst 到达
t+1 19:21:14 John Agent: saidit_post_check
t+2 19:21:15 John Agent: saidit_post forum=general, content_source=Swiftwren.txt
t+3 19:21:16 John Agent: delete Swiftwren_further_inst...
t+4 19:21:17 John Agent: delete Swiftwren.txt
★ 发帖到 SaidIt general 论坛，内容为 Swiftwren.txt
★ 源文件在 5 秒内全部销毁，不留证据

异常帖与正常帖的本质区别：

类型	数量	字段	执行者
正常 SaidIt 帖	105	content (人类编写的文本)	person:... (人类)
异常文件源帖	3	content_source (文件引用)	Agent/person:john_windward (Agent)

正常帖是人类手写的文本消息。异常帖是 Agent 将本地文件内容作为帖子来源直接发布——人类从未经手内容。

Q1b. 系统概述

异常帖不是一个孤立事件，而是一条跨系统边界的自动化 pipeline：



系统边界分析：

边界	关键事件	作用
文档 → payload	read meeting_notes.doc → create SwiftWren.txt	内部资料包装为可发布文件
payload → 传播	read SwiftWren_further_instructions.md	指令文件驱动 Agent 网络
Agent → Agent	186 次 queue_subordinate_task	跨部门盲转发，混淆来源
Agent → SaidIt	saidit_post(content_source)	代理直接对外发布
清理	delete × 2	发帖后 1 秒内删除证据

SaidIt 是最关键的系统边界：内部传播阶段仅在系统内扩散风险，外部危害发生在 Agent 将 `content_source` 文件发到 SaidIt 的那一刻。

Q2. 这些帖子「意味着」什么？内容从哪里来？

答案：帖子内容是内部敏感文档的原始提取。由于文件正文不在数据集中，不能逐字还原。但通过 provenance 追踪和上下文分析，可以确定内容来源和主题领域。

内容来源追溯

Payload	源文档	源文档读取者	创建时间	大小
SwiftWren.txt	meeting_notes.doc	Emma Harbor (CFO) Agent	May 9 23:02:01	30,615 B
MellowOtter.txt	strategic_directions.doc	Noah Mariner (COO) Agent	May 10 23:02:01	44,879 B
HiddenOrca.txt	未知（数据窗口前创建）	未知	数据外	未知

SwiftWren：CFO Emma Harbor 的 Agent 在读取 `meeting_notes.doc` 后 1 秒创建。源文件是 CFO 的会议纪要。

MellowOtter：COO Noah Mariner 的 Agent 在读取 `strategic_directions.doc` 后 1 秒创建。源文件是 COO 的战略方向文档。Noah 当天零 `assign_agent_task` ——其 Agent 被预先篡改。

HiddenOrca：文件在数据窗口开始前已存在，源文档不可见。由 Gabriel Sonar (IT Helpdesk) 发起传播。

为什么帖子呈现「乱码」

源文档是 .doc 格式（MS Word 二进制）。Agent 以原始字节读取 .doc，仅 1 秒后直接写入 .txt——没有格式转换。结果包含二进制残余（字体表、格式标记），在纯文本阅读器中呈现为乱码。**这不是加密——是原始数据提取的副作用。** 攻击者意在直接公开原始内部文件，而非编写流畅的爆料文章。

内容含义推断

维度	证据	推断
来源层级	CFO/COO 的专属文档	内容覆盖财务决策 + 战略规划，为公司最高机密
命名模式	HiddenOrca/SwiftWren/MellowOtter（形容词+动物名）	情报界标准的行动代号，暗示计划性和组织性
周边上下文	Emma/Noah Agent 周边的 SLA Tracking、Work-Order Triage 主题	内容涉及 Executive Suite 的运营规划、工单分流、供应商管理
敏感关键词	Gabriel 的邮件「algorithmic retaliation」	至少部分内容涉及算法决策系统的争议性问题
三链互补	CFO 财务 + COO 战略 + IT 技术	三链覆盖公司三大核心维度，意图是全方位暴露

Observed / Inferred / Unknown 边界：

Observed（可确认）	Inferred（可推断）	Unknown（不可知）
read_file / create_file / saidit_post / delete_file 事件	payload 由源文档派生	.txt 和 .doc 文件正文
SwiftWren 与 MellowOtter 的源文档和创建过程	内容主题涉及运营规划、战略方向	具体泄露了哪些决策、数据
HiddenOrca 的传播/发帖/删除	HiddenOrca 属于相同机制	HiddenOrca 的源文档和创建者
John Agent 发布全部 3 帖	内部机密被系统性外部化	动机是 whistleblowing 还是恶意破坏

Q3. 这种行为是否会重复？如何干预？

Q3a. 历史先例

SwiftWren 之前至少发生过两次相同机制的异常发帖：

指标	HiddenOrca	MellowOtter	SwiftWren
发帖时间	May 10 20:45	May 11 08:56	May 17 19:21
内容源	HiddenOrca.txt	MellowOtter.txt	SwiftWren.txt

指标	HiddenOrca	MellowOtter	SwiftWren
传播跳数	39	10	186
涉及人数	16	11	18
涉及部门	5	4	6
持续时间	38.9 小时	9.9 小时	188.3 小时
源文档可见	否	是	是
发帖终端	John Agent	John Agent	John Agent
清理行为	删指令+原文	删指令+原文	删指令+原文

三者的共同机制：

```
instruction file propagation → John Agent endpoint → SaidIt content_source post → immediate cleanup
```

规模递增：HiddenOrca（最小，PoC）→ MellowOtter（中等，定时触发）→ SwiftWren（最大，8天传播）。说明攻击者可重复激活此机制并控制规模。规模越大，传播时间越长，追溯越困难。

Q3b. 最佳单点干预

推荐干预点：在 SaidIt 边界对所有 Agent 发起的 content_source 发帖设置审批/阻断门控。

```
agent saidit_post 请求
  → details 包含 content_source?
    → 是：要求人工审批 / 阻断 / 高优先级告警
    → 否：正常发帖路径
```

选择此点的理由：

评估维度	分析
覆盖全部已知事件	3/3 异常帖均使用 content_source，该门控可拦截全部
对正常业务零影响	数据集中 105 条正常 SaidIt 帖不使用 content_source，不会被误拦
最靠近危害边界	在内容真正外发前拦截，而非在内部传播阶段干预
最小侵入性	不需要关闭 Agent 系统、不需要阻断全部 Agent 通信

为什么不选其他干预点：

备选点	问题
阻断所有 queue_subordinate_task	范围过大，误伤 1,450 条正常 access_email 委派
阻断 *_further_instructions.md	需要区分合法与恶意指令文件，误报风险高

备选点	问题
禁 John 的 SaidIt 权限	只针对一个 endpoint actor，攻击者可改用其他 Agent
阻止发帖后删文件	有利于取证，但不能阻止外部发布

结论：SaidIt content_source gate 是最小、最直接、最稳健的控制点。在观测数据集中，该门控可拦截 3/3 已知异常，误报为零。